
암호학 프로그래밍



제 1 장 정보보호 개론

목차

1.1 보안 목표와 위협

1.2 보안 서비스와 메커니즘

1.3 암호 시스템과 암호 기술

1.1 보안 목표와 위협

정보에 대한 보안 목표 : CIA

- ✓ 기밀성(Confidentiality), 무결성(Integrity), 가용성(Availability)으로 정의
- ✓ 미국 표준 문서인 FIPS(Federal Information Processing Standard)-PUB 199에서 정의

기밀성을 위협하는 공격

- ✓ 도청(eavesdropping) 트래픽 분석(traffic analysis) 등

무결성을 위협하는 공격

- ✓ 메시지 변경(modification) 혹은 삭제(deletion), 재사용(replaying), 부인(repudiation) 등

가용성을 위협하는 공격

- ✓ 서비스 거부 공격(Denial of Service, DoS)

1.1 보안 목표와 위협

기밀성을 위협하는 공격

- ✓ 단지 정보만을 습득하기 위한 수동적 공격(passive attack)이 대부분

무결성과 가용성을 위협하는 공격

- ✓ 공격자가 악의적 목적을 가지고 적극적인 수단과 방법을 동원하는 적극적 공격(active attack)이 대부분

보안 목표	공격 방법	공격 형태
기밀성	도청	수동적
	트래픽 분석	
무결성	변경 혹은 삭제	능동적
	재사용	
	부인	
가용성	서비스 거부	

[그림 1.1] 보안 목표 및 공격 분류

1.2 보안 서비스와 메커니즘

정보를 보호하는 방법

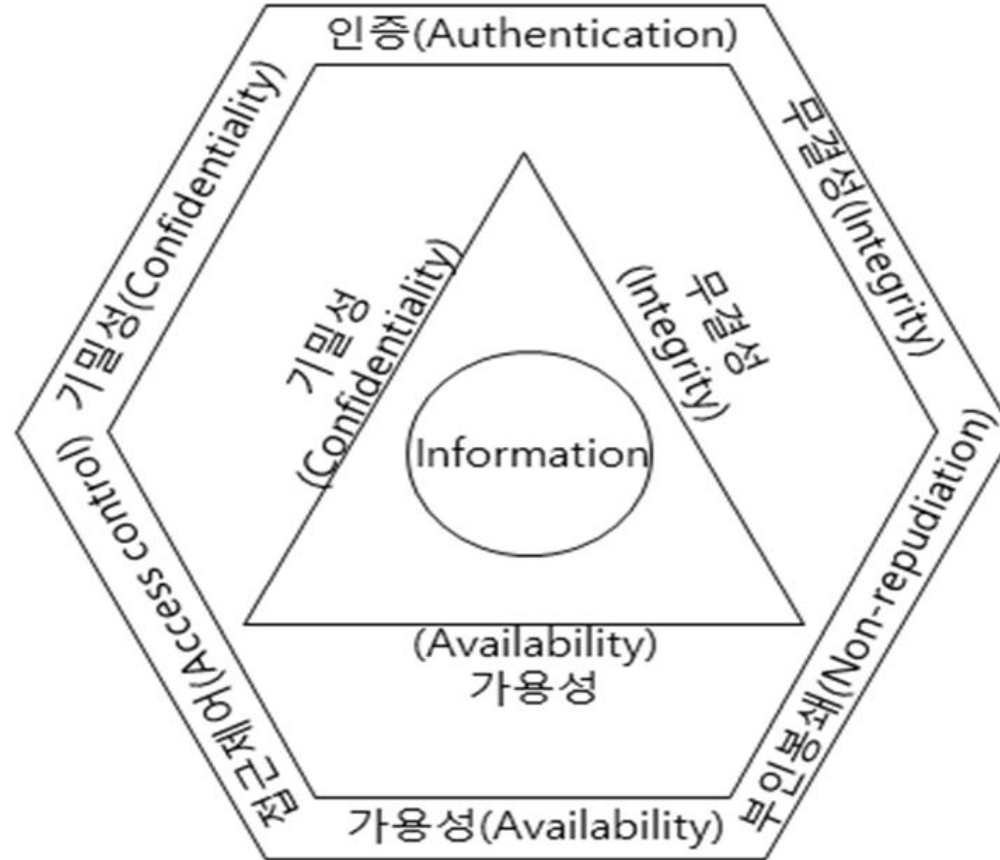
- ✓ 관리적 방법, 법적, 제도적 방법 등을 고려
- ✓ 기술적인 방법이 다양한 형태의 위협에 대응하기 쉽고 이식성과 확장성이 뛰어나 효과적

기술적 대책

- ✓ 보호 대상별 대책
 - 주전산기, 개인용 컴퓨터, 데이터베이스, 네트워크 시스템, 통신 선로 및 소프트웨어의 보호 등
- ✓ 보호 기술별 대책
 - 위험 분석, 패스워드 관리, 스마트카드나 생체특징 등을 이용
- ✓ 보호 서비스별 대책
 - 인증(authentication), 접근 제어(access control), 기밀성(confidentiality), 데이터 무결성(integrity) 및 부인 봉쇄(non-repudiation), 가용성(availability)에 대한 대책

1.2 보안 서비스와 메커니즘

보안 목표 및 정보보호 서비스



[그림 1.2] 보안 목표 및 정보보호 서비스

1.2 보안 서비스와 메커니즘

1) 인증

- ✓ 인증은 수신된 데이터 실체가 요구된 실체라는 것을 확인하는 과정

- ✓ 인증에 적용될 수 있는 기술
 - 알고 있는 것(something known) : 비밀번호
 - 소유하고 있는 것(something possessed) : 물리적인 키나 IC 카드
 - 유일하게 존재하는 것(some immutable characteristic) : 음성이나 지문 등과 같은 생체 특징
 - 신뢰할 수 있는 제 3자(Trusted Third Party, TTP)를 통하여 간접 인증

- ✓ 인증의 종류
 - 대등 실체 인증(entity authentication)
 - 데이터 발신처 인증(data origin authentication)

1.2 보안 서비스와 메커니즘

2) 접근제어

- ✓ 컴퓨터 또는 통신시스템에 관련된 인증되지 않은 행동의 위협에 대항하여 자원의 이용 여부를 결정하는 것
- ✓ 접근 : 정보에 대한 읽기, 쓰기, 변경, 프로그램 실행 등의 권한이 포함
- ✓ 접근제어를 위한 메커니즘 => 접근제어 정책
 - 이런 정책은 사용자와 접근대상이 격자(matrix) 형태로 모델링
 - 예) 사용자 A는 정보 대상 X에는 “읽기”와 “쓰기”가 가능하지만 Y에는 “읽기만 허용한다”라는 정책

1.2 보안 서비스와 메커니즘

3) 기밀성

- ✓ 정보를 가질 권한이 없는 사용자, 실체 혹은 프로세서에게 정보가 노출되거나 이용이 불가능하도록 막는 것
 - ✓ 시스템 사이에 교환되는 데이터, 통신 실체, 그리고 시스템에 의해 처리되는 데이터에 적용
 - ✓ 기밀성 서비스의 형태
 - 채널의 물리적인 보호를 통해 데이터의 접근을 막는 방법
 - 정보를 사상 기술(mapping technique)을 이용하여 정보를 소유하고 있는 자만 제외하고 접근 불가능하도록 보호하는 정보 은닉 방법
- => 암호화(encipherment), 대역확산 (spread spectrum) 및 주파수 도약(frequency hopping) 등

1.2 보안 서비스와 메커니즘

4) 무결성

- ✓ 인증되지 않은 방법으로 데이터를 바꾸거나 손실시키지 않도록 하는 서비스
- ✓ 데이터의 변경(modification)
- ✓ 삭제(deletion)
- ✓ 생성(creation)
- ✓ 삽입(insertion)
- ✓ 재사용(replay) 등

1.2 보안 서비스와 메커니즘

5) 부인 봉쇄

- ✓ 어떤 정보에 관한 행위를 증명할 수 있는 증거를 수집, 유지, 확보하여 부인할 수 없도록 하는 것
- ✓ 부인하는 행위의 논쟁을 중재할 판결권자(adjudicator)와 증거의 확인을 위한 데이터의 확실성과 무결성을 보증할 신뢰성 있는 제 3자, 즉 TTP가 필요
- ✓ 부인봉쇄 서비스 구분
 - 발신처 부인봉쇄(non-repudiation with proof of origin)
 - 보내진 데이터의 내용을 발신자가 부인할 때 사용
 - 메시지가 발신자가 수신자나 가장 공격자(masquerading attacker)에 의해 데이터가 위조되었다고 주장하는 경우
 - 수신처 부인봉쇄(non-repudiation with proof of delivery)
 - 보내진 데이터의 내용을 수신자가 부인할 때 사용
 - 메시지가 보내지지 않았거나 전송 중 잃어버렸거나 혹은 가장 공격자가 수신했다고 수신자 측에서 주장하는 경우

1.2 보안 서비스와 메커니즘

6) 가용성

- ✓ 시스템의 성능에 따라 사용자의 사용 요구가 있을 경우 시스템의 성능 명세에 따라 언제든지 접근이 가능하고 자원을 사용할 수 있도록 제공하는 서비스
- ✓ 즉, 정보 보호 서비스 중간에 발생하는 다양한 공격들로부터 시스템을 확실히 사용하도록 보장하는 것
- ✓ 서비스 거부 공격 등에 대한 보안의 중요성을 강조
- ✓ 시스템 자원의 적절한 관리 및 제어가 필요

1.2 보안 서비스와 메커니즘

보안 서비스와 공격과의 관계

공격 서비스	도청	트래픽 분석	위장	변경	재전송	부인	서비스 거부
인증			0				
접근제어			0				
기밀성	0	0					
무결성				0	0	0	
부인봉쇄						0	
가용성							0

[그림 1.3] 보안 서비스와 공격과의 관계